SECURITY PORTFOLIO

서비스의 동작을 이해하고,
보안 위험을 근거로 설명합니다.

윤승찬 | 정보보호학과 · 정보보안기사

클라우드 · 웹 서비스 · 취약점 점검 · 정보보호 관리체계

정보보호 전공/ 보안 프로젝트 경험

웹 서비스 개발, 클라우드 프로젝트, 취약점 실습과 보안진단을 통해 보안의 여러 관점을 익혔습니다.

윤승찬

수원대학교 정보보호학과

2020.03 – 2026.02

EDUCATION & TRAINING

- 생성형 AI 활용 클라우드&보안 전문가 과정
- SK쉴더스 · SeSAC | 2024.10 – 2025.02

CERTIFICATIONS

- 정보보안기사 · 2026.08
- 정보기기운용기능사 · 2019.08
- 정보처리기능사 · 2019.03
- 컴퓨터활용능력 2급 · 2018.08

Linux · Python · FastAPI · React · Burp Suite · ISMS-P

프로젝트로 확인할 수 있는 경험

수행 프로젝트 | 개인 수행 내용과 결과물을 중심으로 정리했습니다.

AWS 서버리스 공유 앨범

2024.11

보안 점검 의견 제시 · 프로젝트 발표

응답값 노출 점검 · 클라우드 구성 · 차단/TLS 캡처

04—07

SeSAC Community

2024.11

관리자 프론트·백엔드 개발 · 취약점 점검·자문

관리자 API 문서 · CMS 소스 · 인증 구현 및 회고

08—10

ISMS-P·수탁사 보안진단

2025.01—02

준거법 조사 · 담당 체크리스트 작성 · 수탁사 조사

점검표 · 증적 기반 판단 사례 · 팀 진단 결과

11—15

AWS 서버리스 공유 앨범

2024.11 | 클라우드 기반 이미지 업로드·조회·다운로드 서비스 | 팀 프로젝트

담당 역할

정보보호 전공을 바탕으로
보안 점검 의견 제시

위험과 검증 내용을 정리해
프로젝트 발표 담당

팀 기술 환경

S3 · Lambda · API Gateway

MariaDB · WAF · Cognito

대표 사례 | GET 응답의 불필요한 해시값 노출

문제

- 이미지 조회 응답에 비밀번호 해시값이 포함되어,
  서비스 이용에 불필요한 인증 관련 정보가 외부로 전달되는 점

팀 조치

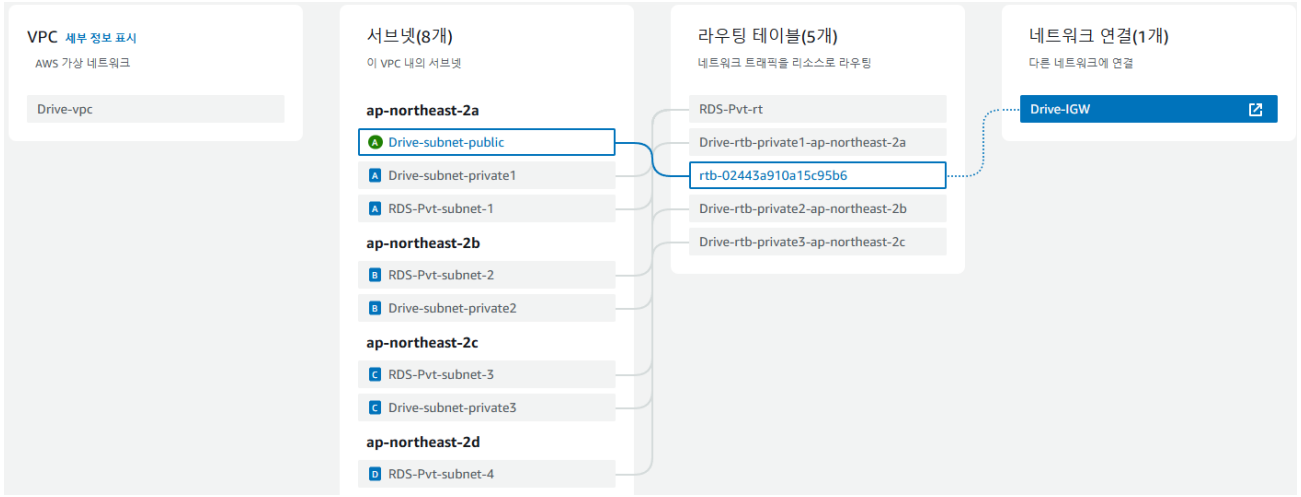
- Lambda 응답에서 비밀번호 해시 필드를 제외하도록 수정.
- 노출 위험과 보안 점검 내용을 팀에 설명 및 해결책 제시

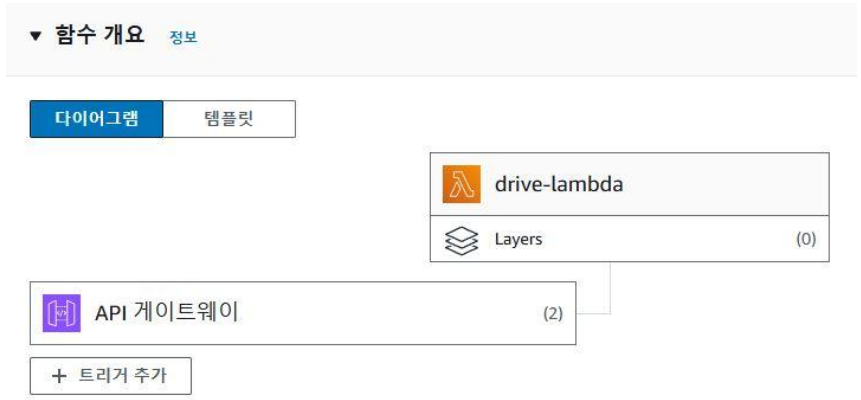
배운 점

- 저장 시 해시 처리 여부와 별개로 API 응답 범위를 확인

AWS 공유 앨범: 클라우드 구성과 서비스 연결

AWS 서버리스 공유 앨범 | 팀이 구축한 서비스의 네트워크 및 API 연결 구조





VPC · 서브넷 · 라우팅 구성

- Public / Private Subnet을 분리
- 인터넷 연결이 필요한 영역과 내부 DB 영역을 Subnet으로 분리
- Public Subnet -> Route Table -> Internet Gateway 연결

API 요청 처리 경로

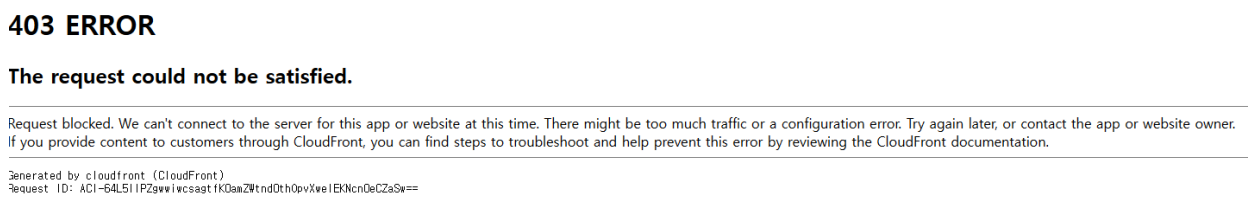
- 사용자 → API Gateway → Lambda → RDS

AWS 공유 앨범: 보안 점검 화면

AWS 서버리스 공유 앨범 | 팀 점검 자료의 차단 사례와 전송 암호화 확인 결과

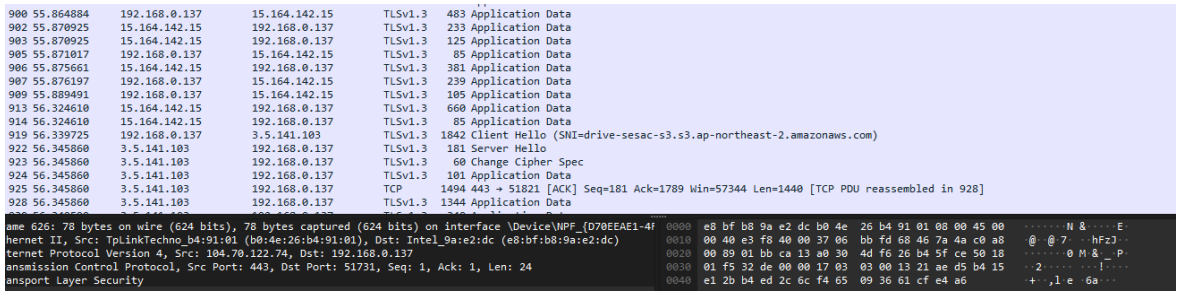
01 공격 요청 차단

- SQL Injection·XSS 공격 시도
- CloudFront와 AWS WAF 연동으로 해결



02 TLS 전송 확인

- Wireshark 캡처에서 TLS 1.3 통신 확인



직접 만든 사이트에서 놓쳤던 보안을 알아가는 학습

AWS 공유 앨범에서 정리한 보안 점검 관점

AWS 서버리스 공유 앨범 |서비스 구조와 보안 적용 사례를 설명하며, 요청,응답과 보호 지점을 함께 살핌

응답데이터도 점검 대상

- GET 응답에서 비밀번호 해시값이 불필요하게 포함된 문제를 확인
- 저장 시 보호 여부뿐 아니라, 클라이언트에 어떤 데이터가 반환 되는지도 점검 해야 한다는 점을 확인

보안 통제마다 보호 지점이 다름

- AWS WAF는 SQL Injection, XSS 요청을 차단, TLS는 전송 구간의 데이터를 보호
- 하나의 보안 기능이 아닌, 공격 요청, 전송, 데이터, 접근 권한처럼 구간별로 다른 통제가 필요함을 이해

구조를 알아야 점검 지점이 보인다

- API Gateway → Lambda → RDS의 요청 흐름과 Public / Private 영역 구성을 살펴봄
- 데이터가 어디로 이동하는지, 어느 구간에서 외부 접근이 제한되는지 알아야 점검 위치를 정할 수 있음

점검 관점 : 서비스 구조 파악 → 데이터 흐름 확인 → 보호지점 확인 → 적용 결과 검증

SeSAC Community: 관리자 기능, 프론트·백엔드 구현

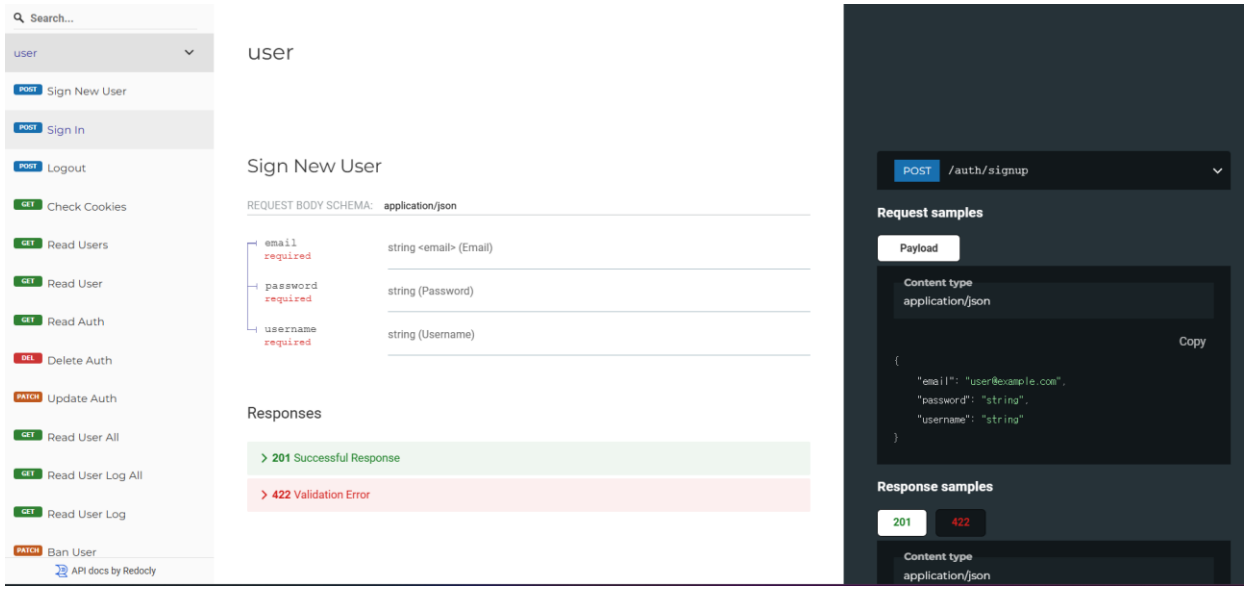
2024.11 | 5인 팀 | 사용자·게시글을 관리하는 SNS 커뮤니티 관리자 페이지 | React + FastAPI(Python)

프로젝트

- 사용자 게시글 작성 및 소통 기능
- 관리자 전용 사용자 · 게시글 관리 기능

담당 역할

- React 기반 관리자 화면 구현
- FastAPI 기반 관리자 API 구현
- 관리자 인증 및 관리 기능 연동
- 보안취약점 점검



관리자 화면 ↔ FastAPI 관리자 API

주요 구현 기능 : 관리자 인증, 사용자관리, 콘텐츠 관리, 운영확인

관리자 인증 구현과 보완점 확인

FastAPI 기반 관리자 로그인 | 비밀번호 검증 → JWT 발급 → 쿠키 저장 → 토큰 갱신

01. 관리자 로그인 인증 흐름

1. 비밀번호 검증
   - bycrypt로 저장된 비밀번호 해시와 입력값 비교
2. JWT 발급
   - Access Token 15분
   - Refresh Token 7일
3. 쿠키 저장
   - HttpOnly, SameSite=Strict 적용
4. 토큰 갱신
   - Access Token 만료 시 Refresh Token 검증 후 재발급
5. 로그 아웃

02. 코드 검토에서 확인한 보완점

- 개발환경 쿠키 설정
  - Secure = False로 구현
  - 운영 시 HTTPS 적용 + Secure=True 필요
- 토큰 디버그 출력
  - Access / Refresh Token을 콘솔에 출력
  - 운영환경에서는 토큰 로그 제거 필요
- 관리 API 인증 적용
  - 일부 관리자 API에 인증 검증이 일관되게 적용되지 않음
- 로그아웃 처리
  - Refresh Token 재사용 방지 방식 검토 필요

확인 관점 : 토큰 발급 → 저장 → 갱신 → API 인증 적용까지 전체 흐름 점검

관리자 기능 개발에서 확인한 점

SeSAC Community | 관리자 페이지 프론트·백엔드 구현 경험

요청 흐름을 코드로 이해

- React 관리자 화면과 FastAPI 백엔드를 함께 구현하며 사용자 동작이 API 요청으로 전달되고 처리 결과가 다시 화면에 반영되는 흐름을 직접 확인
- 기능을 화면 단위가 아니라 요청 → 처리 → 응답의 흐름으로 이해

인증과 인가를 구분

- 로그인 성공과 JWT 발급만으로 관리자 기능 전체가 보호되는 것은 아니다
- 각 관리 API에 인증과 권한 검증이 일관되게 적용되는지 별도로 확인해야 한다는 점을 학습

ISMS-P 갱신 및 수탁사 보안진단

2025.01.06 – 2025.02.25 | 8인 팀 · 수탁사 조사 4인 | 가상 기업 환경의 ISMS-P 갱신 점검과 수탁사 보안진단 | 교육과정 최종 프로젝트 · 팀 대상

01. 프로젝트 상황

- 가상 위탁사 Alpaca Corp.의 ISMS-P 인증 갱신 준비
- 가상 수탁사 Bird Delivery의 개인정보처리 및 보안 수준 점검
- 목표 : 기준에 따라 현황을 진단, 개선방안 도출 산출물 제작

02. 내가 담당한 범위

- Bird Delivery(수탁사) 보안 진단
  - 관련 법령 및 점검 기준 검토
  - 관리체계 1.1~.2.1 체크리스트 작성
  - 인터뷰 사전 준비 및 수행 참여
  - 증적 확인 및 진단 결과 문서 작성

03. 진단 진행 흐름

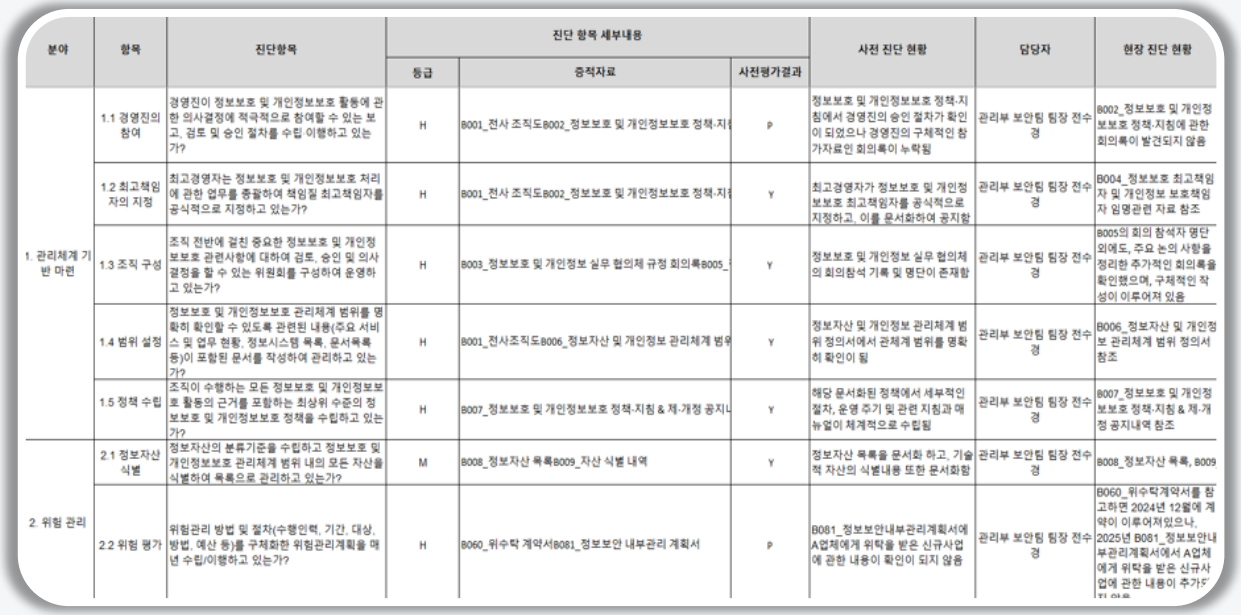
- 법적 근거 확인 → 증적자료 요청서류 작성 → 사전진단 → 인터뷰·현장진단 서류작성 → 최종 보고서 산출물 제작

가상 진단 결과 : 66개 점검 항목 | 53개 양호 | 13개 미흡

ISMS-P 기준을 수탁사 진단 체크리스트로 구체화

ISMS-P 인증기준을 참고해 가상 수탁사의 서비스·위탁업무와 가상 취약 시나리오에 맞는 수탁사 진단 체크리스트를 작성

체크리스트 일부



분야	항목	진단항목	진단 항목 세부내용			사전 진단 현황	담당자	현장 진단 현황
			등급	증적자료	사전평가결과			
1. 관리체계 기반 마련	1.1 경영진의 참여	경영진이 정보보호 및 개인정보보호 활동에 관한 의사결정에 적극적으로 참여할 수 있는 보고, 검토 및 승인 절차를 수립·이행하고 있는가?	H	B001_전사 조직도B002_정보보호 및 개인정보보호 정책·지	P	정보보호 및 개인정보보호 정책·지침에서 경영진의 승인 절차가 확인이 되었으나 경영진의 구체적인 참가자료인 회의록이 누락됨	관리부 보안팀 팀장 전수경	B002_정보보호 및 개인정보보호 정책·지침에 관한 회의록이 발견되지 않음
	1.2 최고책임자의 지정	최고경영자는 정보보호 및 개인정보보호 처리에 관한 업무를 총괄하여 책임질 최고책임자를 공식적으로 지정하고 있는가?	H	B001_전사 조직도B002_정보보호 및 개인정보보호 정책·지	Y	최고경영자가 정보보호 및 개인정보보호 최고책임자를 공식적으로 지정하고, 이를 문서화하여 공지함	관리부 보안팀 팀장 전수경	B004_정보보호 최고책임자 및 개인정보 보호책임자 임명관련 자료 참조
	1.3 조직 구성	조직 전반에 걸친 중요한 정보보호 및 개인정보보호 관련사항에 대하여 검토, 승인 및 의사결정을 할 수 있는 위원회를 구성하여 운영하고 있는가?	H	B003_정보보호 및 개인정보 실무 협의체 규정 회의록B005_	Y	정보보호 및 개인정보 실무 협의체의 회의참석 기록 및 명단이 존재함	관리부 보안팀 팀장 전수경	B005의 회의 참석자 명단 외에도, 주요 논의 사항을 정리한 추가적인 회의록을 확인했으며, 구체적인 작성이 이루어져 있음
	1.4 범위 설정	정보보호 및 개인정보보호 관리체계 범위를 명확히 확인할 수 있도록 관련된 내용(주요 서비스 및 업무 현황, 정보시스템 목록, 문서목록 등)이 포함된 문서를 작성하여 관리하고 있는가?	H	B001_전사조직도B006_정보자산 및 개인정보 관리체계 범위	Y	정보자산 및 개인정보 관리체계 범위 정의서에서 관체계 범위를 명확히 확인이 됨	관리부 보안팀 팀장 전수경	B006_정보자산 및 개인정보 관리체계 범위 정의서 참조
	1.5 정책 수립	조직이 수행하는 모든 정보보호 및 개인정보보호 활동의 근거를 포함하는 최상위 수준의 정보보호 및 개인정보보호 정책을 수립하고 있는가?	H	B007_정보보호 및 개인정보보호 정책·지침 & 제·개정 공지내	Y	해당 문서화된 정책에서 세부적인 절차, 운영 주기 및 관련 지침과 매뉴얼이 체계적으로 수립됨	관리부 보안팀 팀장 전수경	B007_정보보호 및 개인정보보호 정책·지침 & 제·개정 공지내역 참조
2. 위험 관리	2.1 정보자산 식별	정보자산의 분류기준을 수립하고 정보보호 및 개인정보보호 관리체계 범위 내의 모든 자산을 식별하여 목록으로 관리하고 있는가?	M	B008_정보자산 목록B009_자산 식별 내역	Y	정보자산 목록을 문서화 하고, 기술적 자산의 식별내용 또한 문서화함	관리부 보안팀 팀장 전수경	B008_정보자산 목록, B009
	2.2 위험 평가	위험관리 방법 및 절차(수행인력, 기간, 대상, 방법, 예산 등)를 구체화한 위험관리계획을 매년 수립/이행하고 있는가?	H	B060_위수탁 계약서B081_정보보안 내부관리 계획서	P	B081_정보보안내부관리계획서에 A업체에게 위탁을 받은 신규사업에 관한 내용이 확인이 되지 않음	관리부 보안팀 팀장 전수경	B060_위수탁계약서를 참고하면 2024년 12월에 계약이 이루어졌으나, 2025년 B081_정보보안내부관리계획서에서 A업체에게 위탁을 받은 신규사업에 관한 내용이 추가

적용 범위 설정

- 수탁사의 클라우드 서비스와 위탁업무를 분석해 적용할 점검 기준 선별

체크리스트 구체화

- 인증기준을 실제 확인 질문으로 바꾸고 요청 증적·사전평가 기준·법적근거 연결

실제 진단에 활용

- 증적 검토 후 인터뷰·실사진단을 수행하고 현장 확인 내용과 최종평가·개선조치까지 기록

내 수행 흐름 | 적용대상 식별 → 체크리스트 작성 → 증적 요청·검토 → B업체 인터뷰·실사 → 진단 결과 작성 → 주요 취약점 정리

사전 증적과 현장 확인을 거쳐 최종 판정

1.1 경영진의 참여 | 사전평가 P → 현장진단 → 최종 미흡

01. 사전진단

- 확인 기준
  - 경영진의 보고·승인 절차와 실제 참여 여부 확인
- 확인 증적 자료들
  - 전사 조직도
  - 정보보호·개인정보보호 정책·지침
- 사전 평가
  - 정책상 승인 절차는 확인됐으나 실제 참여 기록은 부족 → P

02. 인터뷰·현장진단

- 추가 확인
  - 실제 경영진의 의사결정·참여 기록 확인
- 확인 결과
  - 관련 회의록이 확인되지 않았음

03 개선 방향

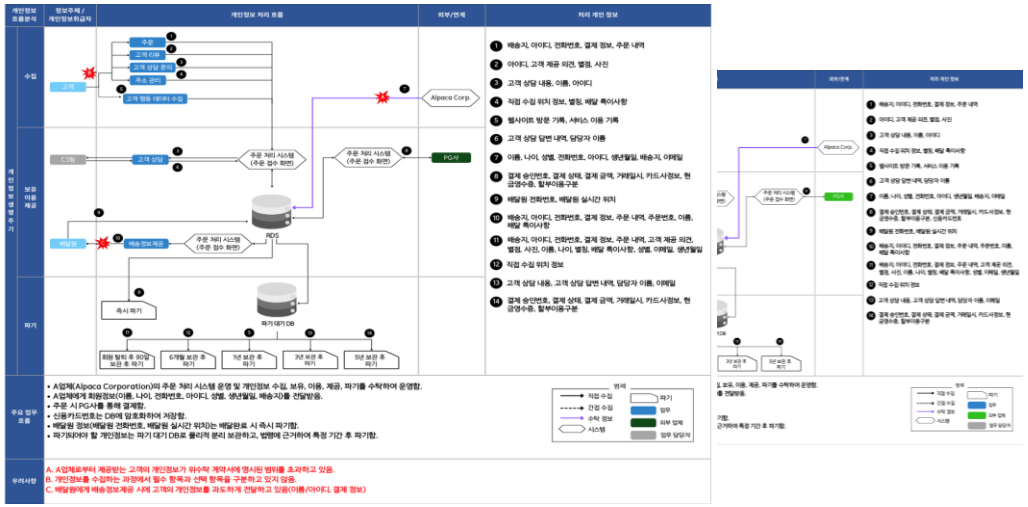
- 최종평가
  - 미흡처리
- 판단 사유
  - 절차는 존재하지만 실제 이행을 확인할 증적 부족
- 개선조치
  - 경영진 의사결정 내용을 확인할 수 있도록 회의록 작성

판단 관점 | 문서상 절차의 존재와 실제 이행 여부를 증적으로 구분해 확인

진단 결과를 개인정보 흐름과 시스템 구조에 연결

수탁사 진단 결과를 업무 흐름과 클라우드 구성에서 다시 확인하고 개선 방향을 정리

01. 개인정보 제공 범위 확인



- 배달원에게 주문 수행에 필요한 범위를 넘어 결제정보와 식별정보가 함께 제공
- 배달 업무에 불필요한 결제정보와 과도한 식별정보 제공 제외

02. 시스템 보호조치 보완

현황

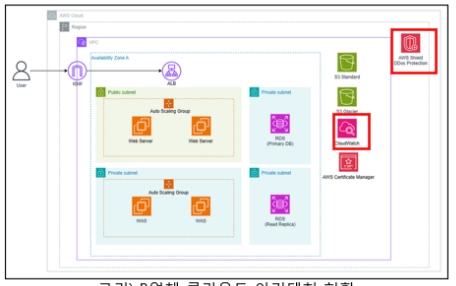


그림) B업체 클라우드 아키텍처 현황

개선방안

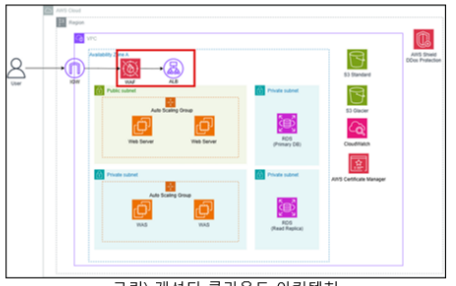


그림) 개선된 클라우드 아키텍처

- 웹 애플리케이션 요청 제어를 위한 WAF 부재
- CloudWatch 로그에 신용카드번호가 암호화되지 않은 상태로 저장
- AWS WAF 도입으로 웹 요청 필터링 강화
  KMS로 로그 암호화, Secrets Manager로 키 관리

보안진단에서 정리한 업무 방식

수탁사 진단을 수행하며 기준을 실제 확인 항목으로 바꾸고, 근거를 판정과 개선조치로 연결

01. 기준을 진단 항목으로 구체화

- ISMS-P 기준을 그대로 나열하지 않고 수탁사의 서비스와 위탁업무에 맞는 항목을 선별
- 요구사항을 실제 확인 질문, 요청, 증적, 사전평가 기준으로 구체화

02. 증적과 현장 확인을 함께 판단

- 제출된 문서만으로 판단이 어려운 사항은 인터뷰·실사진단으로 추가 확인
- 사전평가와 현장 확인 결과를 구분해 최종 판정의 근거로 기록

03. 판정을 개선조치로 연결

- '미흡' 여부에서 끝내지 않고 현황과 판단 근거, 개선할 내용을 함께 정리
- 개선조치와 법적 근거, 담당자·조치기한까지 연결해 결과를 문서화

진단 흐름 | 적용대상 식별 → 기준·증적 구체화 → 사전진단 → 인터뷰·실사 → 최종판정 → 개선조치

서비스 구조를 이해하고, 근거를 바탕으로 보안 위험을 확인합니다

- 웹·클라우드 서비스의 구조와 요청 흐름 이해
- 개발 경험을 바탕으로 인증·권한·데이터 처리 점검
- ISMS-P 기준과 증적을 연결한 수탁사 보안진단 경험

Yoon SeungChan

E-mail | ysc20010202@gmail.com